

Bao cao bai tap lon

De tai 16: Ung dung bao mat tin nhan van ban voi ma hoa AES va xac thuc RSA

Hoc phan: Nhap mon an toan bao mat thong tin

Nam hoc: Hoc ki 3 nam hoc 2025-2026

Thu muc du an: D:\My\ATBMTT

Ngay cap nhat: 25/05/2026

1. Gioi thieu bai toan

Ung dung chat van ban qua mang co nguy co bi nghe len, sua doi, gia mao nguoi gui va gui lai goi tin cu. De tai yeu cau xay dung ung dung bao mat tin nhan bang AES-256-CBC, RSA-2048 va SHA-256. He thong can dam bao tinh bi mat, tinh toan ven, xac thuc nguoi gui va co phan hoi ACK/NACK khi packet hop le hoac bi loi bao mat.

Du an hien tai xay dung ung dung chat that qua WebSocket relay. Moi nguoi dung mo mot tab riêng, tu sinh khoa RSA, dang ky public key len server, gui handshake va message packet qua server trung gian.

2. Yeu cau de tai

Nhom yeu cau		Noi dung
Ma hoa noi dung		AES 256-bit, che do CBC
Trao doi khoa		RSA 2048-bit
Xac thuc		Chu ky so RSA
Padding/hash theo de		PKCS#1 v1.5 + SHA-256
Kiem tra toan ven		SHA-256
Goi tin	IV, ciphertext, hash, signature	
Phan hoi	ACK neu hop le, NACK neu loi integrity/auth	

Bo sung	Anti-replay, test case tan cong, benchmark, threat model
---------	--

3. Muc tieu bao mat

3.1. Tinh bi mat

Noi dung tin nhan duoc ma hoa bang AES-256-CBC truoc khi truyen. Server khong nhan plaintext va khong nam giu khoa AES.

3.2. Tinh toan ven

Receiver tinh lai:

```
SHA-256(IV || ciphertext)
```

Neu hash tinh lai khac hash trong packet, receiver tu choi va gui NACK.

3.3. Xac thuc

Sender ky metadata va payload message bang RSA/SHA-256. Receiver dung public key cua sender de verify signature.

3.4. Anti-replay

Moi message co `session_id` va `sequence_number`. Receiver luu sequence number da xu ly. Neu packet cu bi gui lai, receiver phat hien va NACK.

3.5. Packet het han

Moi packet co `timestamp`. Ung dung tu choi packet co timestamp qua cu de mo phong yeu cau het han/sai quyen trong huong dan bo sung.

4. Kien truc he thong

```
Flowchart LR
```

```
A["Nguoi dung 1\nClient crypto"] --> S["Relay/Server"]
```

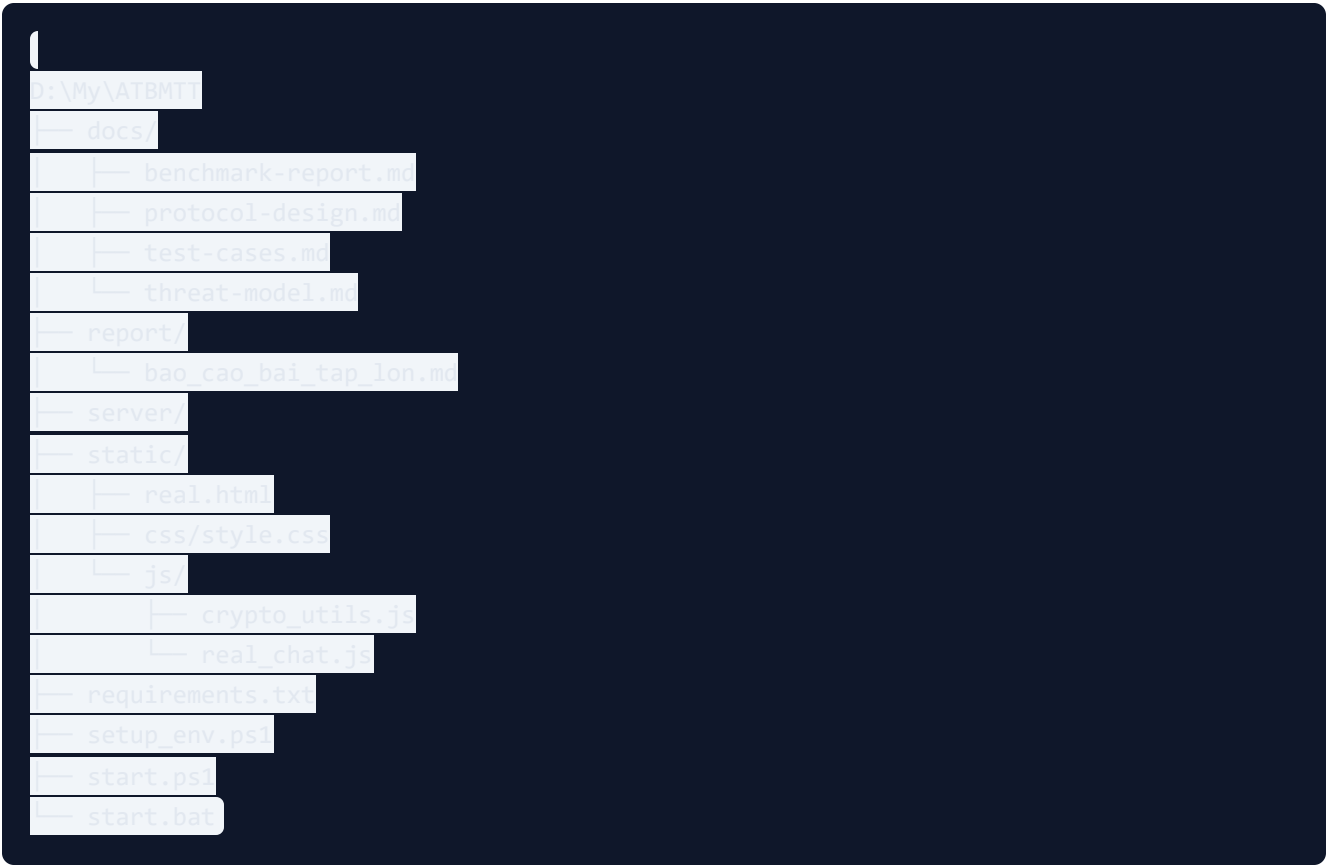
```
S --> B["Nguoi dung 2\nClient crypto"]
```

```
B --> S
```

```
S --> A
```

Trong ban trien khai hien tai, moi nguoi dung dang nhap bang ID ca nhan tren mot tab rieng. Backend FastAPI serve frontend, luu public key in-memory va relay WebSocket packet giua cac client.

Cau truc thu muc



5. Threat model

Moi nguy	Mo ta	Co che phong thu trong ung dung
Nghe len	Doc packet tren duong truyen	AES-256-CBC
Sua ciphertext	Thay doi du lieu ma hoa	SHA-256 hash mismatch
Gia mao nguoi gui	Tao packet gia	RSA signature verify
Replay	Gui lai packet cu	sequence_number
Sai nguoi nhan	Chuyen packet cho user khac	RSA decrypt AES key fail
Packet cu	Timestamp qua han	timestamp window
MITM public key	Server phan phoi public key gia	Ghi nhan la han che, can fingerprint/QR

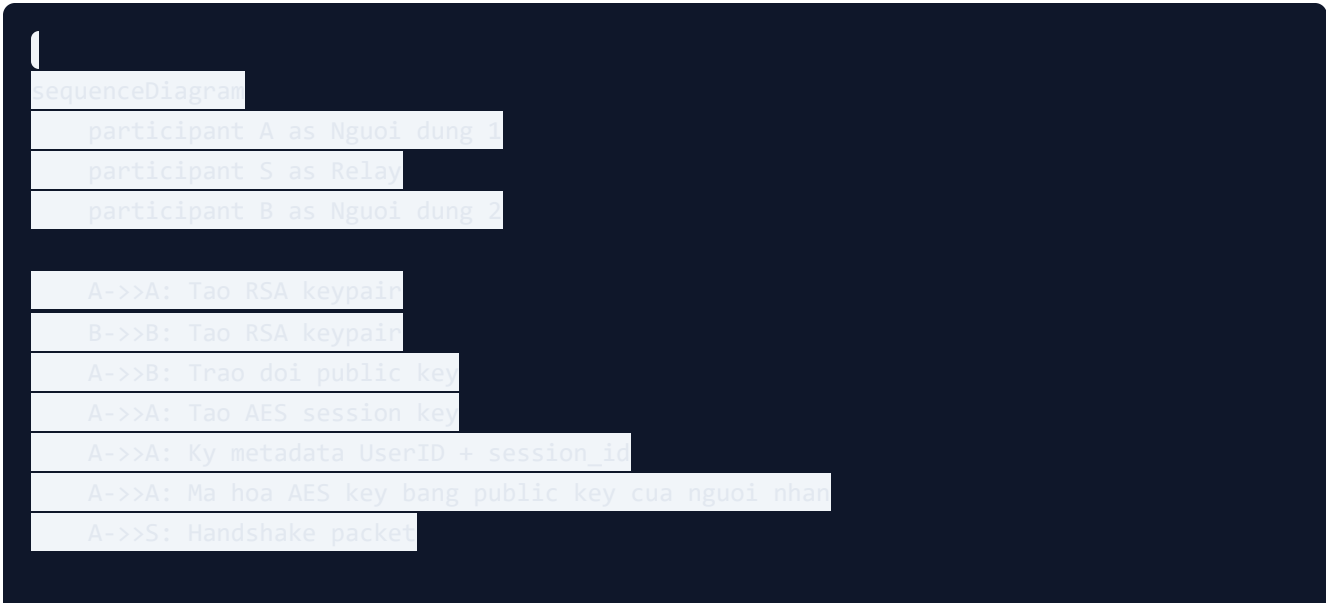
6. Thuật toán và thư viện

Thanh phần		Công nghệ
Backend		Python FastAPI
Server runtime		Uvicorn
Database		SQLite
Frontend		HTML, CSS, JavaScript
AES	Web Crypto API AES-CBC 256-bit	
RSA	node-forge RSA-2048 PKCS#1 v1.5 + SHA-256	
Hash		SHA-256

Lưu ý kỹ thuật: Web Crypto API trên browser không hỗ trợ đầy đủ RSAES-PKCS1-v1_5 encryption, vì vậy dự án dùng `node-forge` cho RSA PKCS#1 v1.5. AES-CBC và SHA-256 vẫn dùng Web Crypto API của trình duyệt.

7. Thiết kế giao thức

7.1. Handshake



S->>B: Relay handshake

B->>B: Verify signature va giai ma AES key

7.2. Gui message

```
sequenceDiagram
    participant A as Nguoi dung 1
    participant S as Relay
    participant B as Nguoi dung 2

    A->>A: AES-256-CBC encrypt
    A->>A: SHA-256(TV || ciphertext)
    A->>A: RSA sign payload
    A->>S: Message packet
    S->>B: Relay packet
    B->>B: Check timestamp
    B->>B: Check replay
    B->>B: Verify hash
    B->>B: Verify signature
    B->>B: AES decrypt
    B->>A: ACK/NACK
```

Thu tu xu ly tai receiver:

Kiem tra timestamp.

Kiem tra replay bang sequence number.

Kiem tra hash.

Kiem tra chu ky.

Giai ma AES.

Hien thi message va gui ACK.

8. Chuc nang da cai dat

Chuc nang	Trang thai
Giao dien chat that 2 tab	Da co
Server relay WebSocket o giua	Da co
Luu public key va security log bang SQLite	Da co

Nhieu ket noi WebSocket cho cung mot user	Da co
Tao RSA keypair client-side	Da co
Tao AES key va IV	Da co
Ma hoa AES-256-CBC	Da co
SHA-256 integrity hash	Da co
Ky va verify payload	Da co
ACK/NACK trong ung dung	Da co
Chua replay bang sequence number	Da co
Tu choi packet het han	Da co
Che do 2 tab WebSocket that	Da co
Kiem thu sua ciphertext qua WebSocket	Da co
Kiem thu sai chu ky qua WebSocket	Da co
Kiem thu packet het han qua WebSocket	Da co
Kiem thu replay qua WebSocket	Da co
Tai lieu threat model	Da co
Tai lieu test cases	Da co
Tai lieu benchmark	Da co
Checklist trien khai	Da co

9. Kich ban chay that

Mo trinh duyet tai:

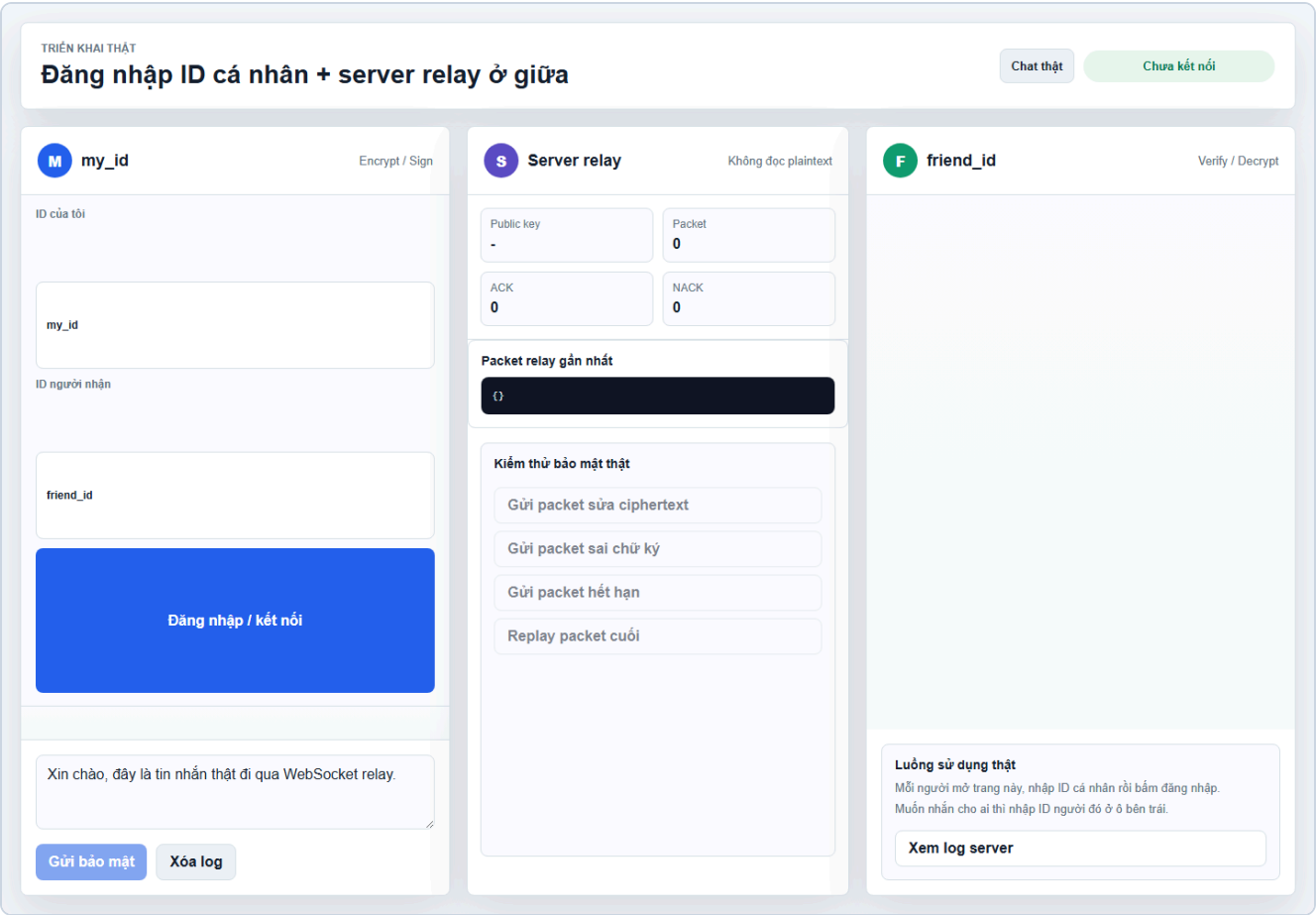
```
http://127.0.0.1:8010/
```

Moi nguoi dung mo trang ung dung, nhap ID ca nhan va ID nguoi nhan:



Tai moi tab bam Dang nhap / ket noi , sau do gui tin. Server o giua chi relay packet va hien packet gan nhât, khong doc plaintext.

Anh minh chung giao dien



10. Kiem thu bao mat

Test case	Dau vao	Ket qua mong doi
TC01	Message hop le	ACK
TC02	Peer offline	NACK user offline
TC03	Gui tin hai chieu	Moi ben nhan duoc plaintext dung

TC04	Sender mismatch qua packet thu cong	Server NACK sender mismatch
TC05	Sua ciphertext	Receiver NACK integrity
TC06	Sai chu ky	Receiver NACK signature
TC07	Packet het han	Receiver NACK expired
TC08	Replay packet	Receiver NACK replay
TC09	Crypto self-test	npm run test:crypto thanh cong
TC10	WebSocket relay self-test	npm run test:relay thanh cong

11. Huong dan cai dat

```
cd D:\My\ATBMTT
.\setup_env.ps1
.\start.ps1
```

Neu PowerShell chan script:

```
powershell -ExecutionPolicy Bypass -File .\start.ps1
```

Kiem tra lop crypto riêng:

```
npm run check:js
npm run test:crypto
npm run test:relay
```

Che do trien khai that:

```
http://127.0.0.1:8010/
```

12. Han che va huong phat trien

Han che con lai:

- Public key distribution mac dinh tin tuong server.
- Log server hien luu in-memory, chua co database.

Huong phat trien:

- Luu security log tren server.
- Them database public key fingerprint.
- Them QR/fingerprint public key de giam MITM.
- Them export benchmark thanh file.
- Mo rong che do WebSocket de ho tro phong chat nhieu nguoi va luu log dai han.

13. Ket luan

Du an da xay dung duoc ung dung chat bao mat chay that qua WebSocket relay theo de tai 16. Lop RSA dung `node-forge` de bam sat RSA-2048 PKCS#1 v1.5 + SHA-256; AES-CBC va SHA-256 duoc xu ly bang Web Crypto API. San pham hien cho phep moi nguoi dang nhap bang ID ca nhan, mo nhieu tab/client that va trao doi packet qua server trung gian chi relay, khong doc plaintext.